

Prepared Statements

- **Prepared Statements** are precompiled SQL statements that can be executed multiple times efficiently, with different parameters. So, they are parametric SQL statements

```
String sql = "INSERT INTO coffee (brand, price) VALUES (?,?)";
```

The «?» are placeholders of the parameters that will be bound dynamically at runtime

So, prepared statements separates SQL statement logic from the data being used in the statements

33

Why prepared statements?

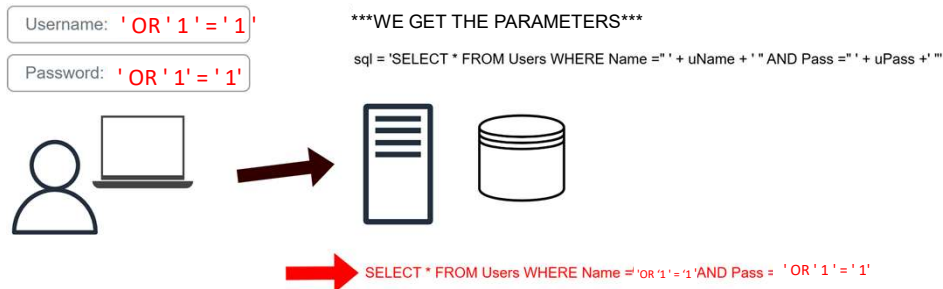
- They can be reused multiple times with different parameters, reducing the need to re-compile the statement, thus improving performance for frequently executed statements
- They prevent SQL injection



34

SQL Injection

- SQL injection is a very common web hacking strategy



35

SQL injection & prepared statements

- Using prepared statements, the SQL engine binds the values to the placeholder (?) before executing the statement
- So, the values are treated as data and not as a part of SQL syntax

36

Let's play again with our DB

esempio19

37

Something more

- Up to now, we used H2 as an in-memory DB, in production web app you need having data saved somewhere
- So, you need to specify connection properties in the application.properties file to define the DB location, credential to authenticate (ok, not very safe!)

38

Working with H2 in embedded mode

- We need to modify the application.properties file

```
spring.datasource.url=jdbc:h2:file:./data/testdb;AUTO SERVER=TRUE
spring.datasource.username=sa
spring.datasource.password=

# esegue script SQL all'avvio (not needed when H2 is in-memory mode)
spring.sql.init.mode=always
```

- As usual create SQL files in `src/main/resources/`
(Pay attention if your file names are different from the default ones!)

39

Accessing the Embedded H2 Database from IntelliJ

- Open IntelliJ:
 - Go to the Database panel
 - Click on '+' to add a Data source and choose H2
 - Configure the connection
 - Fill up URL, username and password as in the application file
 - Test your connection (press the button and then OK)
 - Check the schema in the Database

40

@Home

- Modify esempio 19 by using an embedded H2 database

esempio20